

ACTIVIDAD 04: UNA PÁGINA DEMASIADO CONVINCENTE

CNO IV (T37A): Seguridad Informática

Alumno: Alejandro García Morales
Profesor: Mtro. Servando López Contreras

Contenido

1. OBJETIVO DE LA ACTIVIDAD	2
1.1. Objetivo General	2
2. DESCRIPCIÓN DEL ESCENARIO	2
2.1. Caso Institucional	2
2.2. Fundamentos Teóricos:	2
¿Qué es un Credential Harvester y cuál es su función en una campaña de phishing?	2
3. CONFIGURACIÓN DEL LABORATORIO	3
3.1. Topología y Entorno de Red	3
3.2. Herramientas y Tecnologías Utilizadas	3
3.3. Implementación de la Página Web Ficticia y funcionamiento del Código	3
4. EVIDENCIAS Y DESCRIPCIÓN DEL FUNCIONAMIENTO	4
4.1. Ejecución del Módulo Credential Harvester en SET	4
4.2. Visualización e Interacción desde el Cliente Víctima	5
4.3. Interceptación de Parámetros HTTP POST en Tiempo Real	5
4.4. Persistencia y Almacenamiento de los Datos en Archivo Local	5
5. EXPLICACIÓN DEL FLUJO DE CAPTURA DE INFORMACIÓN	6
5.1. Diagrama de Flujo del Ataque	6
5.3. Distinción Técnica: Captura de Credenciales vs. Vulneración / Ruptura de Contraseñas.....	7
6. CONTROLES DE SEGURIDAD	7
6.1. Cinco Indicadores para Reconocer una Página Fraudulenta.....	7
6.2. Cinco Controles de Seguridad Propuestos	8
7. CONCLUSIÓN	9
8. REFERENCIAS	10

1. OBJETIVO DE LA ACTIVIDAD

1.1. Objetivo General

Realizar una simulación de ingeniería social mediante Social-Engineer Toolkit (SET) en un entorno de laboratorio controlado, utilizando una página web ficticia para comprender el funcionamiento de una técnica de captura de información y reconocer los elementos técnicos y visuales que permiten identificar un intento de phishing.

2. DESCRIPCIÓN DEL ESCENARIO

2.1. Caso Institucional

El equipo de seguridad informática de una organización ficticia identificó una serie de notificaciones emitidas por empleados respecto a la recepción de correos electrónicos sospechosos. Dichos mensajes notificaban a los usuarios sobre una supuesta "expiración de sesión" e incluían un hipervínculo que los dirigía a un portal de autenticación institucional aparentemente auténtico.

La interfaz del portal fraudulento incluye la identidad visual corporativa (logotipo, tipografía, paleta de colores institucional), campos de captura para usuario y contraseña, y un banner preventivo indicando: "Su sesión ha expirado. Inicie sesión nuevamente para continuar." A pesar de que los elementos visuales transmiten legitimidad, el portal está alojado en una dirección de red ajena a la infraestructura oficial y tiene como único fin interceptar los datos de acceso para obtener un vector de entrada a la red empresarial.

2.2. Fundamentos Teóricos:

¿Qué es un Credential Harvester y cuál es su función en una campaña de phishing?

Es un servicio o script malicioso configurado para interceptar, extraer y persistir identificadores de acceso (nombres de usuario, correos electrónicos, contraseñas en texto claro) que una víctima ingresa en un formulario web.

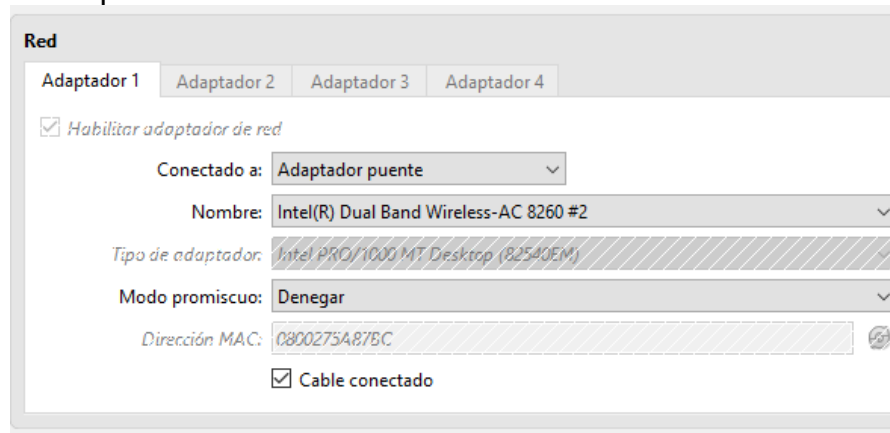
Dentro de una campaña de phishing, el Credential Harvester cumple el rol de fase de recolección de credenciales para acceso inicial. Su función no es explotar vulnerabilidades de software en el navegador ni forzar algoritmos criptográficos, sino abusar de la confianza del usuario mediante la suplantación de identidad, capturando las credenciales exactamente en el formato en que son enviadas por el protocolo HTTP antes de que lleguen a cualquier sistema legítimo.

3. CONFIGURACIÓN DEL LABORATORIO

3.1. Topología y Entorno de Red

El laboratorio se estructuró mediante un enlace directo de red local entre dos entornos:

- **Máquina Atacante (Servidor SET):** Máquina virtual con Kali Linux (IP asignada: 192.168.0.191), configurada con interfaz de red en modo Adaptador Puente para obtener una dirección IP en el mismo segmento que la máquina anfitriona.



- **Máquina Víctima (Cliente):** Sistema operativo Windows conectado a la misma red local (IP asignada: 192.168.0.107), utilizando un navegador web estándar para acceder a la URL suministrada.
- **Puerto de Escucha:** Puerto TCP 80 (HTTP estándar).

```
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

3.2. Herramientas y Tecnologías Utilizadas

- Sistema Operativo Atacante: Kali Linux 2026 / GNU/Linux.
- Framework de Ingeniería Social: Social-Engineer Toolkit (SET) versión 8.0.3
- Lenguajes de Marcado y Estilo: HTML5 y CSS3 nativo con gráficos vectoriales SVG escalables integrados(Usados para crear un logo directamente en el código HTML).

3.3. Implementación de la Página Web Ficticia y funcionamiento del Código

Para cumplir con las restricciones éticas del laboratorio, se programó desde cero un portal institucional para la empresa ficticia **Zboz** (Zboz Systems).

Explicación del código:

1. **Estructura Semántica y Encabezado (<header> y SVG):** Se usó un elemento <svg> inline con fondo transparente para renderizar el isotipo corporativo de Zboz de forma vectorial. Esto garantiza que la imagen cargue instantáneamente y sin requerir solicitudes HTTP secundarias a otros archivos de imagen.
2. **Mensaje de Expiración (.alert-box):** Se colocó un bloque visual con colores de alerta (#fff8c5, borde #bf8700) simulando una sesión caducada para inducir sentido de urgencia psicológica.
3. **Formulario de Captura (<form>):**
 - method="POST": Define que los datos viajen encapsulados en el cuerpo de la solicitud HTTP en lugar de quedar expuestos en la URL.
 - action="": Al estar vacío, el navegador envía el formulario a la misma dirección IP y recurso desde el cual se cargó el sitio (http://192.168.0.190/), donde SET está escuchando activamente.
 - Campos de Entrada (<input>): Se definieron los atributos name="username" y name="password". El valor del atributo name es fundamental, ya que SET analiza e identifica estas etiquetas estándar para extraer automáticamente el texto ingresado.

4. EVIDENCIAS Y DESCRIPCIÓN DEL FUNCIONAMIENTO

4.1. Ejecución del Módulo Credential Harvester en SET

Se inició la herramienta en Kali Linux mediante el comando `sudo setoolkit`. Después, se seleccionaron las siguientes opciones del menú interactivo(en el orden que aparecen:

1. 1) Social-Engineering Attack
2. 2) Website Attack Vectors
3. 3) Credential Harvester Attack Method
4. 3) Custom Import

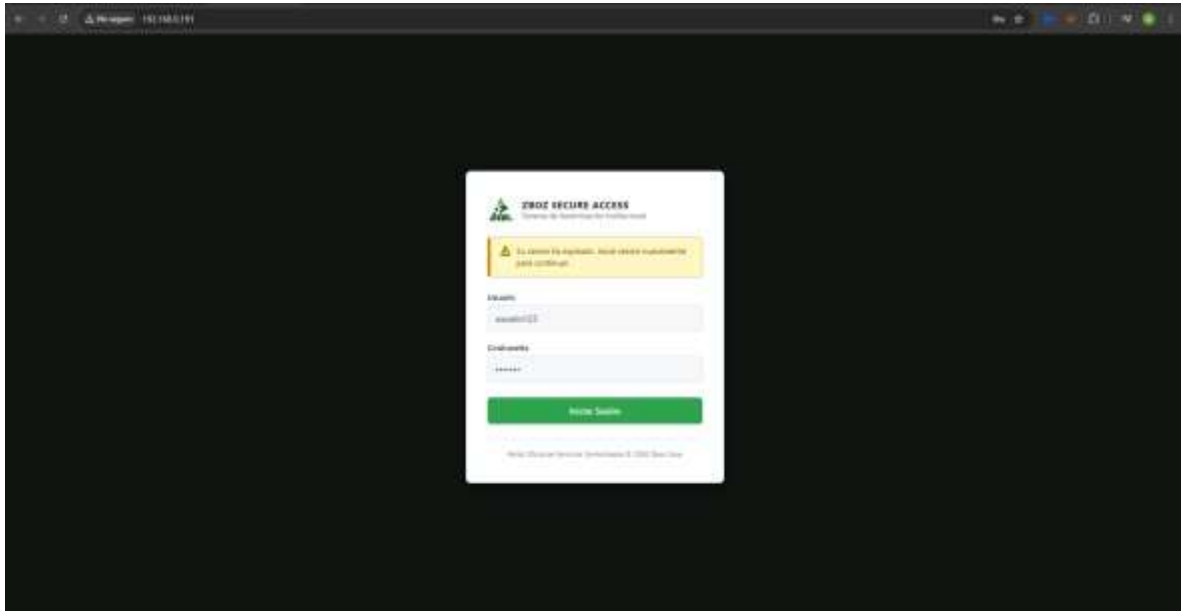
Se especificó la dirección IP local de la máquina (192.168.0.191) como destino de retorno del POST, y se proporcionó la ruta del directorio local que contiene el archivo index.html desarrollado (/home/kali/Documents/Act_4/).

```
setoolkit> IP address for the POST back in Harvester/Tabnabbing [192.168.0.191]:
Example: /home/website/ (make sure you end with /)
Also note that there MUST be an index.html in the folder you point to.
setoolkit> Path to the website to be cloned: /home/kali/Documents/Act_4/
Index.html found. Do you want to copy the entire folder or just index.htm
1?
1. Copy just the index.html
2. Copy the entire folder
Enter choice [1/2]: 1
Example: http://www.blah.com
setoolkit> URL of the website you imported: http://zboz.com

You will see a pop-up window in 10 seconds and you will see the following:
- The Social-Engineer Toolkit Credential Harvester Attack
- Credential Harvester is running on port 80
- Information will be displayed to you as it arrives online.
```

4.2. Visualización e Interacción desde el Cliente Víctima

Desde la máquina anfitriona (Windows), se ingresó al navegador web dirigiéndose a la dirección [http://192.168.0.191].



Se introdujeron datos ficticios de prueba en el formulario para validar la transmisión:

- **Usuario / Matrícula:** usuario123
- **Contraseña:** prueba1

4.3. Interceptación de Parámetros HTTP POST en Tiempo Real

Al hacer clic en el botón **"Iniciar Sesión"**, el navegador envió la solicitud al servidor web montado por SET. En la terminal de Kali Linux se observó la recepción inmediata de la petición POST, registrando la IP de procedencia de la víctima (192.168.0.107) y extrayendo en texto claro los parámetros username y password.

```
[*] Information will be displayed to you as it arrives below:
192.168.0.108 - - [01/Sep/2026 01:35:22] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=usuario123
POSSIBLE PASSWORD FIELD FOUND: password=prueba1
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

4.4. Persistencia y Almacenamiento de los Datos en Archivo Local

Una vez terminada la demostración, se finalizó el listener presionando Ctrl + C. SET procesó la sesión y generó automáticamente un reporte persistente dentro del directorio de reportes (/root/.set/reports/).

Para comprobar que los datos se conservan íntegros después de la ejecución, se consultó el archivo de reporte generado en la terminal:

Bash

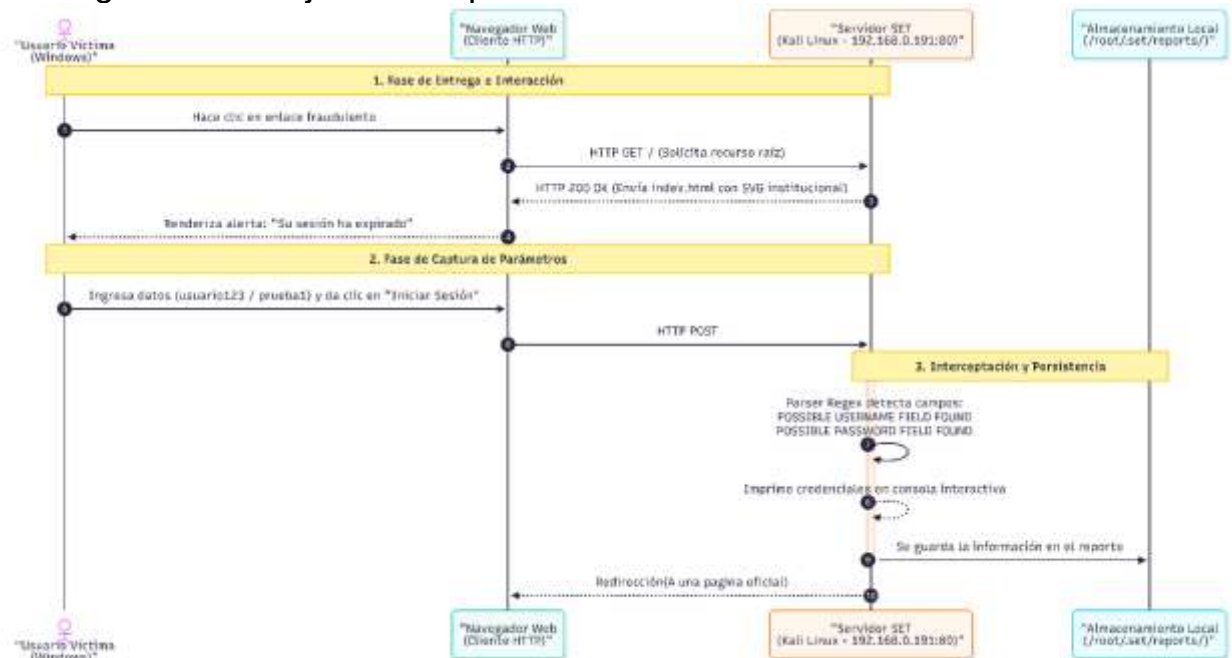
```
sudo cat /root/.set/reports/*.txt
```

[INSERTAR AQUÍ CAPTURA DE PANTALLA 5]

Figura 5. Verificación de la persistencia de datos mediante la consulta del archivo de reporte generado por SET tras finalizar el proceso.

5. EXPLICACIÓN DEL FLUJO DE CAPTURA DE INFORMACIÓN

5.1. Diagrama de Flujo del Ataque



5.2. Desglose del Ciclo de Petición-Respuesta HTTP

- Fase de Entrega (HTTP GET):** El navegador web solicita el recurso raíz / al servidor web en la IP 192.168.0.191. SET responde con un código de estado HTTP 200 OK y transfiere el contenido del archivo index.html.
- Fase de Entrada de Datos e Interacción:** La víctima visualiza la página, la cual emula la identidad institucional. El mensaje de sesión expirada persuade al usuario para reingresar sus credenciales sin verificar la autenticidad del origen.
- Fase de Transmisión (HTTP POST):** Al oprimir el botón de envío, el navegador empaqueta los valores dentro de los campos <input> bajo el estándar application/x-www-form-urlencoded. Debido a que la conexión viaja sobre el protocolo HTTP, la trama viaja en texto legible a través del canal de red.

4. **Fase de Extracción y Volcado:** SET recibe la carga útil, extrae las llaves coincidentes con nombres comunes de autenticación y las registra tanto en el buffer de la consola como en el sistema de archivos del sistema operativo atacante (/root/.set/reports/).

5.3. Distinción Técnica: Captura de Credenciales vs. Vulneración / Ruptura de Contraseñas

Es indispensable establecer una distinción técnica clara entre ambos conceptos:

- **Captura de Credenciales (*Credential Harvesting*):** Es un ataque basado en suplantación de identidad e ingeniería social. El atacante no requiere vulnerar bases de datos, romper hashes criptográficos ni adivinar combinaciones mediante fuerza bruta. Es el propio usuario autorizado que, engañado por el contexto y la apariencia visual, entrega voluntariamente sus credenciales en texto plano al servidor ilegítimo.
- **Vulneración de Contraseñas (*Password Cracking*):** Es un ataque de carácter criptoanalítico o de fuerza bruta. Consiste en atacar un repositorio de autenticación previamente para revertir o descifrar la contraseña original mediante ataques de diccionario, tablas arcoíris o computación acelerada por GPU (utilizando herramientas como Hashcat o John the Ripper).

En esta práctica se demostró que el error humano y la ausencia de controles criptográficos de transporte e identidad permiten la recolección de credenciales sin necesidad de alterar la seguridad interna de los sistemas organizacionales.

6. CONTROLES DE SEGURIDAD

6.1. Cinco Indicadores para Reconocer una Página Fraudulenta

N	Indicador de Phishing	Tipo	Descripción Técnica / Visual
1	Dirección IP directa o Dominio Discrepante	Técnico	El portal se accede mediante una dirección IP directa (ej. http://192.168.0.190) o un dominio con una letra diferente en lugar del nombre de dominio normal (ej. microsoft.com).
2	Ausencia de Protocolo HTTPS / Certificado Inválido	Técnico	El navegador marca el sitio como "No seguro" debido a la carencia de un certificado TLS emitido por una Autoridad Certificadora (CA) de confianza.
3	Urgencia Injustificada	Visual / Contextual	Utilización de mensajes alarmistas no solicitados ("Su sesión ha expirado", "Acceso bloqueado en 24h") para precipitar la acción del usuario.

4	Comportamiento Anómalo tras el Envío	Técnico / Funcional	Al enviar el formulario, la página no inicia sesión real: recarga la misma pantalla, genera un error 404 o redirige a un sitio genérico sin preservar el estado de la sesión.
5	Incompatibilidad con Gestores de Contraseñas	Técnico	Los gestores de contraseñas de los navegadores vinculan las credenciales al dominio raíz. Si el sitio es falso, el gestor no ofrece la función de autocompletado para ese portal.

6.2. Cinco Controles de Seguridad Propuestos

1. Autenticación Multifactor Resistente al Phishing (FIDO2 / WebAuthn)

- **Justificación:** Requiere que el usuario presente un segundo factor criptográfico vinculado al dominio legítimo antes de autorizar el acceso.
- **Alcance:** Neutraliza de raíz el ataque de recolección de credenciales. Aunque el atacante obtenga el usuario y la contraseña en texto plano, no podrá autenticarse en los sistemas de la empresa al carecer de la llave de seguridad de hardware o del token biométrico.
- **Limitaciones:** Costo elevado de despliegue de llaves físicas, resistencia inicial al cambio por parte de los usuarios y necesidad de compatibilidad en todos los sistemas legados institucionales.

2. Filtrado DNS y Pasarelas Web Seguras (Secure Web Gateway - SWG)

- **Justificación:** Inspección y bloqueo a nivel de red de conexiones dirigidas a direcciones IP directas, dominios de reciente o categorías sospechosas.
- **Alcance:** Impide que los equipos corporativos dentro de la red o conectados mediante VPN puedan resolver o abrir URLs alojadas en servidores maliciosos o atacantes no categorizados.
- **Limitaciones:** Resulta ineficaz si el empleado accede desde un dispositivo personal fuera del perímetro corporativo sin un agente de seguridad instalado, o si el atacante aloja el formulario en un servicio en la nube reputado (ej. formularios de Google).

3. Protocolos de Autenticación de Correo Electrónico (SPF, DKIM y DMARC)

- **Justificación:** Implementación estricta de políticas DMARC con regla de rechazo (p=reject) para validar el origen y la integridad de los correos corporativos.
- **Alcance:** Bloquea correos electrónicos que intenten suplantar la identidad de la organización antes de que ingresen a la bandeja de entrada de los empleados.

- **Limitaciones:** No previene ataques donde el adversario utiliza dominios parecidos pero diferentes ni cuando el vector de contacto inicial ocurre por canales externos (ej. SMS).

4. Uso Obligatorio de Gestores de Contraseñas Corporativos con Vinculación Estricta de Dominio

- **Justificación:** Los gestores de contraseñas validan criptográficamente la URL antes de permitir el llenado automático de credenciales.
- **Alcance:** Si el usuario accede a una página clonada que opera bajo una IP o un dominio falso, el gestor se rehúsa a autocompletar la contraseña, alertando al usuario de que el portal no coincide con el registro legítimo.
- **Limitaciones:** El control puede ser evadido si el usuario ignora la advertencia y copia y pega manualmente sus credenciales desde el gestor hacia los campos del formulario.

5. Programas Continuos de Concientización y Simulaciones de Phishing

- **Justificación:** Entrenamiento periódico del personal mediante ejercicios simulados basados en técnicas reales de ingeniería social.
- **Alcance:** Capacita a los colaboradores para reconocer elementos sospechosos en enlaces, verificar certificados de seguridad y reportar oportunamente los incidentes al área de ciberseguridad.
- **Limitaciones:** El sesgo humano impide alcanzar una efectividad del 100%; un porcentaje residual de usuarios siempre será susceptible a señuelos altamente dirigidos (spear phishing).

7. CONCLUSIÓN

La realización de esta práctica permitió comprender de manera directa el funcionamiento técnico de las técnicas de recolección de credenciales mediante el uso de herramientas de ingeniería social como Social-Engineer Toolkit (SET). Se comprobó que el vector de ataque analizado explota una vulnerabilidad inherente a la naturaleza humana: la tendencia a responder con rapidez ante mensajes de urgencia (como la expiración de una sesión) dentro de entornos de trabajo dinámicos.

Desde la perspectiva técnica, el ejercicio demostró que un atacante no requiere romper algoritmos de cifrado ni comprometer los servidores centrales de una empresa para obtener credenciales válidas; basta con replicar los elementos visuales de una interfaz y canalizar el tráfico a través de peticiones HTTP POST estándar para capturar información confidencial en texto plano.

Por consiguiente, se concluye que la seguridad informática organizacional no puede depender exclusivamente del criterio de los usuarios ni de una única barrera perimetral. Resulta indispensable adoptar un enfoque de Defensa en Profundidad, donde el entrenamiento continuo del factor humano se complementa de manera obligatoria con controles tecnológicos robustos, tales como la autenticación multifactor(2FA), el filtrado web automatizado y políticas rigurosas de autenticación de correo.

8. REFERENCIAS

- **Kennedy, D.** (2020). *The Social-Engineer Toolkit (SET) User Manual (v8.0)*. TrustedSec, LLC. <https://github.com/trustedsec/social-engineer-toolkit>
- **MITRE Corporation.** (2026). *Phishing: Spearphishing Link (T1566.002) - MITRE ATT&CK Matrix for Enterprise*. MITRE ATT&CK. <https://attack.mitre.org/techniques/T1566/002/>
- **National Institute of Standards and Technology.** (2020). *Digital Identity Guidelines: Authentication and Lifecycle Management* (NIST Special Publication 800-63B). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-63b>
- **Zeltser, L.** (2021). *Analyzing and Defending Against Credential Harvesting Campaigns*. SANS Institute Information Security Reading Room. <https://www.sans.org/white-papers/>